

VULNERABILITY ASSESSMENT REPORT

Target Website: testfire.net

A publicly accessible demonstration web application used for cybersecurity learning and vulnerability assessment practice.

Prepared By: Nadipalli Sai Hasith
Future Interns: Cyber Security Task 1

1. Introduction

Overview

This assessment set out to check the security posture of the target web application using passive, non-intrusive testing—nothing that pokes, breaks, or changes anything. The goal was simple: find publicly visible weaknesses without exploiting a single one of them or touching any application data.

The work covered gathering information about the app, digging through HTTP traffic, spotting the technologies running under the hood, checking HTTP security headers, reviewing the SSL/TLS setup, and doing some basic network reconnaissance. Everything stayed read-only, and every step followed standard ethical assessment practice.

2. Objective

Here's what this assessment aimed to do:

- Identify publicly accessible security weaknesses
- Perform passive reconnaissance of the target website
- Evaluate HTTP security headers and SSL/TLS configuration
- Identify the technologies used by the web application
- Provide practical recommendations for improving the overall security posture

3. Scope of Assessment

Item	Details
Target Website	testfire.net
Assessment Type	Passive Vulnerability Assessment
Assessment Method	Read-only Security Analysis
Testing Scope	Publicly Accessible Resources Only

4. Ethical Considerations

Only passive techniques were used here. No exploitation, no authentication bypass, no brute-force attempts, no denial-of-service testing, no unauthorized access of any kind. Everything stayed inside ethical boundaries, working only with information that's already public.

5. Tools Used

These tools handled the information-gathering and analysis work during the passive vulnerability assessment. Each one had a specific job to do in the process.

Assessment Workflow

The assessment moved through these steps, in order:

- Information gathering using Nmap
- Passive HTTP traffic analysis using Burp Suite
- Identification of web technologies using Wappalyzer
- Evaluation of HTTP security headers using SecurityHeaders
- Analysis of SSL/TLS configuration using SSL Labs
- Documentation of findings and preparation of recommendations

Assessment Approach

The whole thing followed a passive methodology—only publicly accessible information got collected. No active attacks, no exploitation attempts, no unauthorized modifications anywhere along the way.

Tool Purpose

Tool	Purpose
Burp Suite Community Edition	Captured and analyzed HTTP requests and responses during browsing
Nmap	Identified open ports, running services, and basic network exposure
SecurityHeaders	Evaluated the implementation of HTTP security headers
SSL Labs	Assessed the SSL/TLS configuration and certificate validity
Wappalyzer	Identified the web server, programming language, and underlying technology stack

6. Target Website Overview

Overview

The site is built with security gaps on purpose, which makes it a solid, safe place to practice vulnerability assessment techniques without breaking anything real.

The assessment focused only on publicly available pages without attempting authentication or exploitation.

Parameter	Details
Target Website	testfire.net
Website Type	Online Banking Demo Application
Assessment Method	Passive Vulnerability Assessment
Testing Scope	Public Pages Only
Assessment Status	Completed Successfully

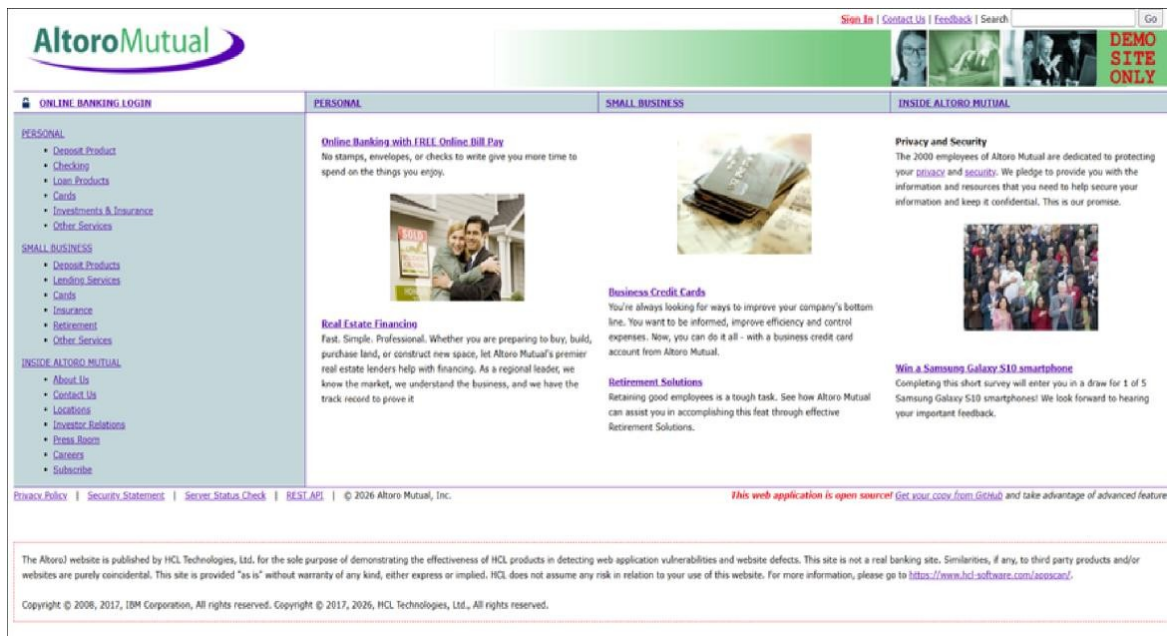


Figure 1: Homepage of the target web application (testfire.net).

Homepage Observation

The homepage links out to several public sections, and those sections were what got used for passive information gathering throughout the assessment.

7. Network Reconnaissance Using Nmap

Overview

Nmap handled the network recon here, pulling together publicly available information about the target host. The objective was to identify accessible network services and understand the exposed attack surface, without performing intrusive or exploitative actions.

The scan was limited to passive information gathering and was conducted against the publicly accessible domain testfire.net.

Tool Used

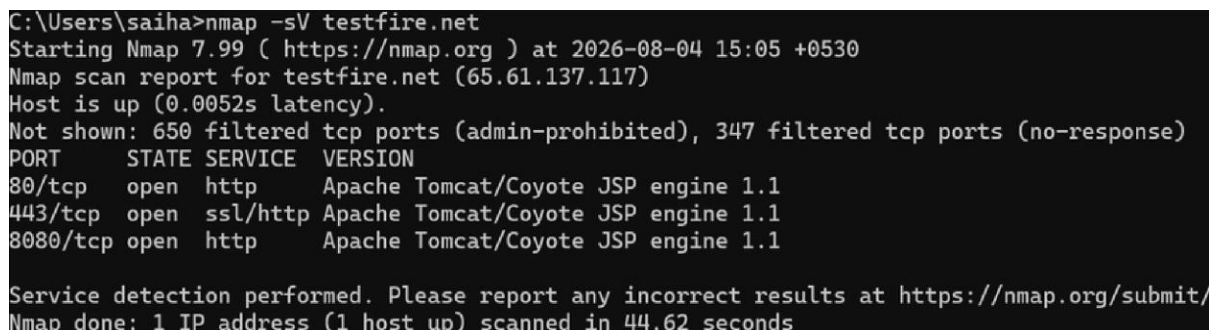
- Tool: Nmap
- Purpose: Network reconnaissance and service detection

Commands Executed

Nmap -sV testfire.net

Scan Observation

The scan ran successfully and pulled up the services active on the target. Nmap tries to spot open ports and figure out which service versions are running—handy for understanding which network services are exposed, and whether any outdated or unnecessary services are widening the attack surface.



```
C:\Users\saiha>nmap -sV testfire.net
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-04 15:05 +0530
Nmap scan report for testfire.net (65.61.137.117)
Host is up (0.0052s latency).
Not shown: 650 filtered tcp ports (admin-prohibited), 347 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache Tomcat/Coyote JSP engine 1.1
443/tcp   open  ssl/http Apache Tomcat/Coyote JSP engine 1.1
8080/tcp  open  http    Apache Tomcat/Coyote JSP engine 1.1

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 44.62 seconds
```

Figure 2: Nmap service detection command executed against the target website.

Analysis

The Nmap scan gave a first look at the target's publicly exposed network services. This reconnaissance became the starting point for the passive web application work that followed, using Burp Suite and the other security analysis tools.

8. Burp Suite Analysis

Overview

Burp Suite Community Edition handled passive web traffic analysis—capturing and inspecting the HTTP requests and responses exchanged between the browser and the target website. This made it possible to observe communication details such as request methods, response headers, cookies, and server information, without modifying or exploiting the application.

Purpose of Using Burp Suite

- Capture HTTP requests and responses
- Observe website communication with the server
- Identify server information exposed in HTTP responses
- Review cookies and response headers
- Support passive vulnerability assessment



#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start response...
1	http://testfire.net	GET	/		✓	200	9451	HTML	jsp	Altoro Mutual			65.61.137.117	JSESSIONID=SEE...	14:51:11.4 A...	8080	309
11	http://testfire.net	GET	/index.jsp?content=inside_about...		✓	200	7939	HTML	jsp	Altoro Mutual			65.61.137.117		14:58:54.4 A...	8080	299
13	http://testfire.net	GET	/index.jsp?content=inside_contact...		✓	200	10095	HTML	jsp	Altoro Mutual			65.61.137.117		14:59:00.4 A...	8080	336
15	http://testfire.net	GET	/index.jsp?content=inside_invest...		✓	200	8288	HTML	jsp	Altoro Mutual			65.61.137.117		14:59:13.4 A...	8080	309
17	http://testfire.net	GET	/index.jsp?content=inside_careers...		✓	200	8319	HTML	jsp	Altoro Mutual			65.61.137.117		14:59:20.4 A...	8080	304
19	http://testfire.net	GET	/index.jsp?content=privacy.htm		✓	200	12604	HTML	jsp	Altoro Mutual			65.61.137.117		14:59:28.4 A...	8080	305
20	http://testfire.net	GET	/index.jsp?content=security.htm		✓	200	11317	HTML	jsp	Altoro Mutual			65.61.137.117		14:59:33.4 A...	8080	316
22	http://testfire.net	GET	/swagger/index.html		✓	200	1655	HTML	html	Swagger UI			65.61.137.117		14:59:40.4 A...	8080	280
26	http://testfire.net	GET	/swagger/properties.json		✓	200	9603	JSON	json				65.61.137.117		14:59:49.4 A...	8080	233
28	https://online.swagger.io	GET	/validator?url=http%3A%2F%2Fte...		✓	302	325	HTML		302 Found		✓	18.233.145.92		14:59:50.4 A...	8080	268

Figure 3: HTTP History captured while browsing the target website using Burp Suite.

Observations

- Multiple HTTP requests were successfully captured
- Public web pages responded with HTTP 200 OK
- The captured traffic was used for passive analysis only

9. HTTP Request and Response Analysis

Overview

The Request and Response Inspector in Burp Suite was used to examine the communication between the client and the server. This analysis helps in understanding how the web application processes requests and what information comes back in the server response.

Captured Request and Response

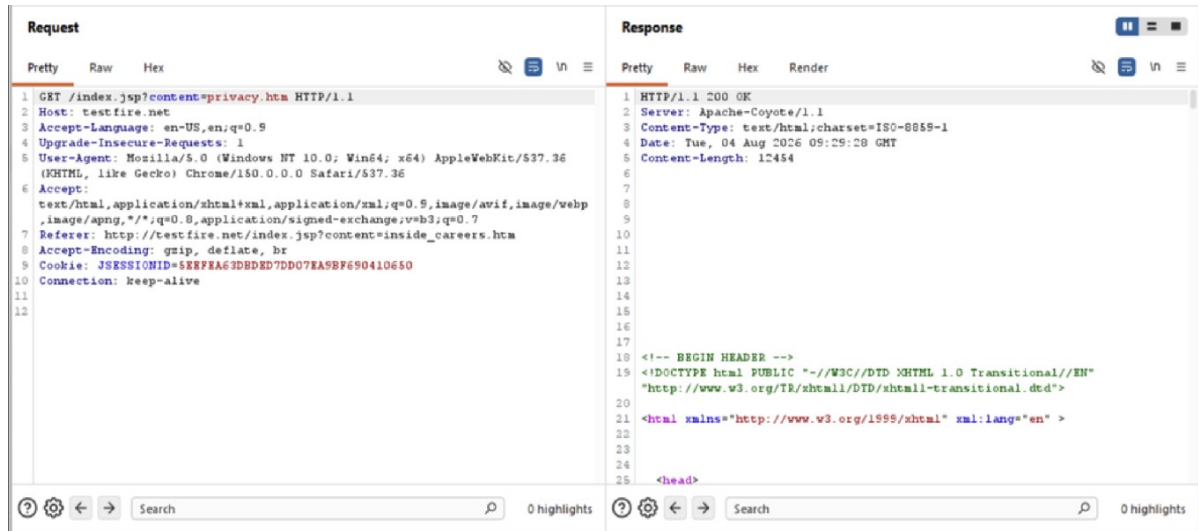


Figure 4: HTTP request and corresponding server response captured using Burp Suite.

Analysis

The captured request shows the client accessing a publicly available webpage using the HTTP GET method. The server responded successfully with an HTTP 200 OK status, indicating the requested resource was available. Response headers also revealed server information and session management details, useful during passive reconnaissance.

Conclusion

The Request and Response analysis confirmed normal communication between the client and the web server. No requests were modified, and no exploitation techniques were used during this step.

10. Technology Fingerprinting Using Wappalyzer

Overview

Wappalyzer was used to identify the technologies powering the target website through passive analysis. The extension detects publicly visible technologies without interacting with or modifying the web application.

Purpose

- Identify the web server technology
- Detect the programming language/framework
- Understand the application's technology stack
- Support passive reconnaissance

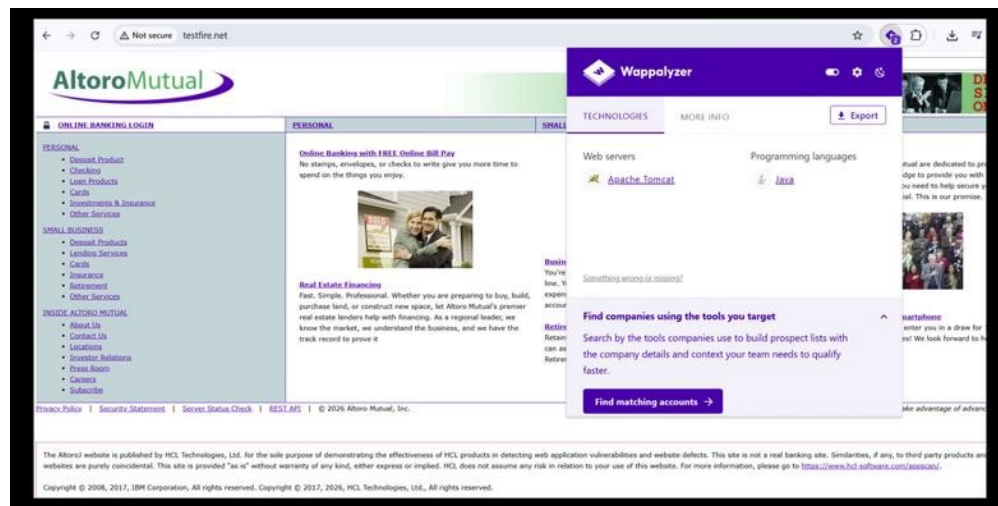


Figure 5: Technology fingerprinting using Wappalyzer.

Technology	Description
Apache Tomcat	Java-based web application server
Java	Programming language used by the application

Analysis

The passive fingerprinting results indicate that the application is hosted on Apache Tomcat and developed using Java.

Conclusion

Wappalyzer successfully identified the primary technologies used by the target website without performing any intrusive actions.

11. Security Headers Analysis

Overview

SecurityHeaders.com was used to evaluate the HTTP security headers configured on the target website. Security headers help protect web applications against common attacks such as clickjacking, cross-site scripting (XSS), and MIME-type sniffing.

Purpose

- Assess HTTP security header configuration
- Identify missing or weak security headers
- Evaluate the website's overall security posture

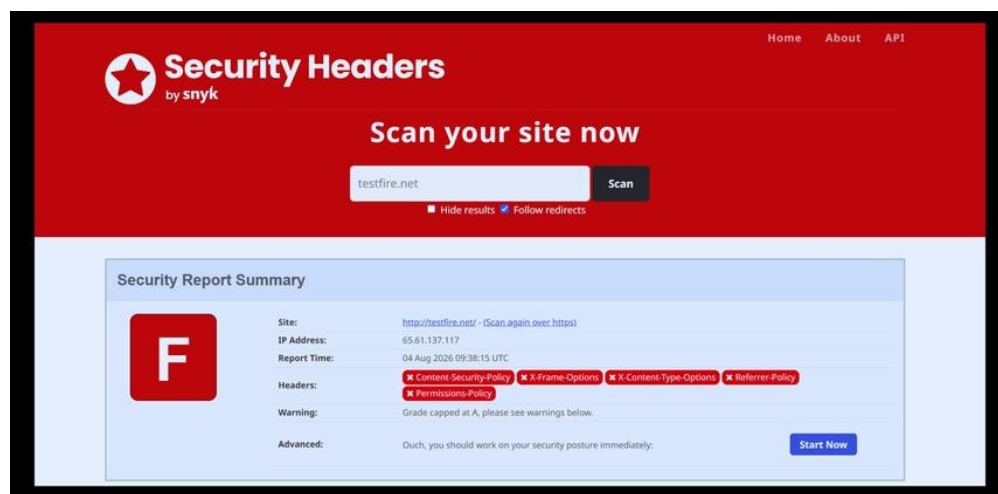


Figure 6: Security headers assessment.

Finding	Status
Overall Grade	F
Content-Security-Policy	Missing
X-Frame-Options	Missing
X-Content-Type-Options	Missing
Referrer-Policy	Missing
Permissions-Policy	Missing

Analysis

The assessment indicates that several recommended HTTP security headers are not configured on the target website.

12. SSL/TLS Assessment

SSL Labs was used to evaluate the SSL/TLS configuration of the target website. The assessment reviewed the server's security configuration and overall SSL/TLS implementation.

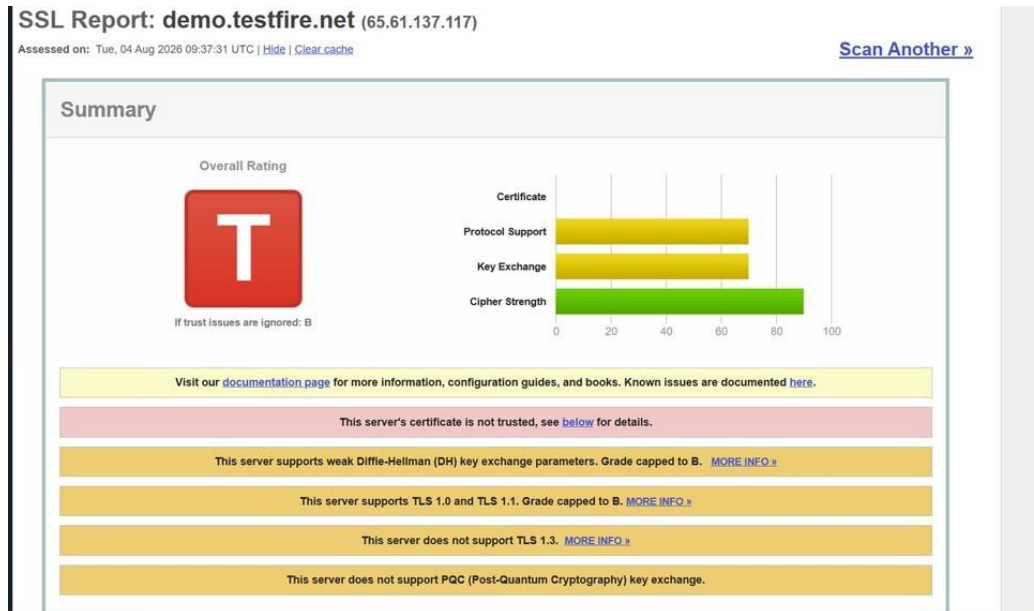


Figure 7: SSL/TLS assessment summary.

Key Observations

- Overall Rating: T
- Certificate trust issue detected
- TLS configuration requires improvement
- Cipher strength is acceptable

SSL Certificate Details

Certificate #1: RSA 2048 bits (SHA256withRSA)	
Server Key and Certificate #1	
Subject	demo.testfire.net Fingerprint SHA256: b0eac225501db594a9639f9e718bc03675969492c7c729a60c9473568393382 Pin SHA256: bf3ouC0SiVnY+uSmrz65yC6g48AmK5EUA9hsh0=
Common names	demo.testfire.net
Alternative names	demo.testfire.net
Serial Number	0850b6e8f9775ebc97689eb83fb716d
Valid from	Wed, 21 May 2025 00:00:00 UTC
Valid until	Sun, 21 Jun 2026 23:59:59 UTC (expired 1 month and 13 days ago) EXPIRED
Key	RSA 2048 bits (e 65537)
Weak key (Debian)	No
Issuer	Sectigo RSA Domain Validation Secure Server CA AIA: http://crt.sectigo.com/SectigoRSADomainValidationSecureServerCA.crt
Signature algorithm	SHA256withRSA
Extended Validation	No
Certificate Transparency	Yes (certificate)
OCSP Must Staple	No
Revocation information	OCSP OCSP: http://ocsp.sectigo.com
Revocation status	Unchecked (only trusted certificates can be checked)
DNS CAA	No (more info)
Trusted	No NOT TRUSTED (Why?) Mozilla Apple Android Java Windows

Figure 8: SSL certificate information.

Key Findings

- Certificate Status: Expired
- Valid Until: 21 June 2026
- Key Size: RSA 2048-bit
- Signature Algorithm: SHA256withRSA
- Issued by: Sectigo RSA Domain Validation Secure Server CA

Analysis

The SSL certificate has expired, causing browsers to treat the website as untrusted. In addition, support for older TLS versions and the absence of TLS 1.3 indicate that the SSL/TLS configuration should be updated to align with current security best practices.

13. Overall Findings and Recommendations

The passive vulnerability assessment identified several security observations on the target website. The assessment was limited to publicly accessible information and did not include exploitation or intrusive testing.

Finding	Risk Level
Missing HTTP Security Headers	High
Expired SSL Certificate	High
Support for TLS 1.0 and TLS 1.1	Medium
Server Information Disclosure	Low
Technology Fingerprinting Possible	Low

Recommendations

- Configure recommended HTTP security headers (Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, and Permissions-Policy)
- Renew the expired SSL/TLS certificate
- Disable outdated TLS 1.0 and TLS 1.1 protocols and enable TLS 1.3
- Minimize unnecessary server information exposed through HTTP response headers
- Perform regular vulnerability assessments and security updates to maintain a secure environment

Risk Summary

The assessment indicates that the website would benefit from improvements in HTTP security header configuration and SSL/TLS settings. Addressing these issues will strengthen the application's overall security posture and reduce exposure to common web-based attacks.

14. Conclusion

This vulnerability assessment wrapped up successfully using passive security testing to check the publicly accessible parts of the target web application. Throughout the assessment, no intrusive actions, exploitation attempts, or unauthorized modifications were performed.

A handful of security observations came out of it—missing HTTP security headers, an expired SSL certificate, support for outdated TLS protocols, and publicly identifiable server technologies. While the target website is intentionally designed for cybersecurity education, the findings still mirror the kind of issues that show up in real-world applications. Tools such as Nmap, Burp Suite Community Edition, Wappalyzer, SecurityHeaders, and SSL Labs provided valuable insight into the application's security posture, and the recommended improvements would help strengthen confidentiality, integrity, and secure communication if applied to a production environment.

Overall, this assessment built practical understanding of passive vulnerability assessment methodologies, web application reconnaissance, and professional security reporting.

Key Learning Outcomes

- Gained practical experience with passive vulnerability assessment
- Learned to use multiple cybersecurity tools for information gathering
- Analyzed HTTP traffic and web server responses
- Evaluated HTTP security headers and SSL/TLS configuration
- Prepared a structured vulnerability assessment report based on collected evidence

Acknowledgement

This report was prepared as part of a Cyber Security Internship to demonstrate the application of passive web security assessment techniques and professional documentation practices.